
개인정보보호 및 정보보안 기본지침

2025. 10. 1.



건설근로자공제회

개인정보보호 및 정보보안 기본지침 관리요령

이 지침은 건설근로자공제회 본회·지사(센터를 포함한다)에서 근무하는 임직원 등의 개인정보보호 및 정보보안 업무수행에 필요한 사항을 규정한 것으로, 발행처 허가 없이 기관 내 부서 또는 지사 이외의 개인·단체에 제공하여서는 아니 되며 외부 인터넷에 유통되지 않도록 주의하여 주시기 바랍니다.

목 차

제1장 총 칙	1
제1조(목적)	1
제2조(다른 지침과의 관계)	1
제3조(정의)	1
제4조(개인정보 보호 원칙)	4
제5조(적용범위)	5
제6조(책무)	5
제2장 개인정보보호	6
제1절 개인정보보호책임자 및 내부관리계획	6
제7조(개인정보보호책임자의 지정 및 역할)	6
제8조(개인정보보호책임자의 공개)	7
제9조(개인정보 분야별책임자의 지정 및 역할)	7
제10조(개인정보 내부관리계획 수립 및 시행)	8
제11조(연도 추진계획 수립)	8
제12조(실태점검)	9
제13조(개인정보보호 교육)	9
제2절 개인정보 처리방침	9
제14조(개인정보 처리방침의 기재사항)	9
제15조(개인정보 처리방침의 공개)	10
제16조(개인정보 처리방침의 변경)	10

제3장 정보보안	11
제17조(정보보안책임자 운영)	11
제18조(정보보안담당관 운영)	11
제19조(분임정보보안담당관 운영)	12
제20조(연도 추진계획 수립)	12
제21조(정보보안감사)	12
제22조(정보보안 교육)	13
제23조(사이버보안진단의 날)	13
제4장 정보화사업 보안	14
제1절 사업 계획	14
제24조(보안책임)	14
제25조(보안대책 수립)	14
제26조(제안요청서 기재사항)	15
제2절 보안성 검토	16
제27조(검토 시기 및 절차)	16
제28조(검토 대상)	16
제29조(검토 생략)	17
제30조(제출 문서)	18
제31조(검토결과 조치)	18

제3절 계약 및 사업 수행	19
제32조(계약 특수조건)	19
제33조(용역업체 보안)	19
제34조(발주기관내 작업장소 보안)	21
제35조(원격지 개발보안)	22
제36조(원격지에서의 온라인 개발)	22
제5장 정보통신망 및 정보시스템 보안	24
제1절 정보통신망 보안	24
제37조(내부망 · 인터넷망 분리)	24
제38조(클라우드컴퓨팅 보안)	25
제39조(보안 · 네트워크장비 보안)	26
제40조(인터넷전화 보안)	27
제41조(인터넷 사용제한)	28
제2절 정보시스템 보안	28
제42조(정보시스템 보안책임)	28
제43조(정보시스템 유지보수)	29
제44조(지정 단말기를 통한 온라인 유지보수)	29
제45조(서버 보안)	30
제46조(공개서버 보안)	31

제47조(로그기록 유지)	31
---------------------	----

제48조(원격근무 보안)	32
---------------------	----

제3절 자료 보안	34
------------------------	-----------

제49조(비공개 업무자료 처리)	34
-------------------------	----

제50조(비공개 업무자료 유출방지)	35
---------------------------	----

제51조(공개 업무자료 처리)	35
------------------------	----

제52조(홈페이지 등 게시자료 보안)	35
----------------------------	----

제4절 사용자 보안	36
-------------------------	-----------

제53조(개별사용자 보안)	36
----------------------	----

제54조(단말기 보안)	36
--------------------	----

제55조(계정 관리)	37
-------------------	----

제56조(비밀번호 관리)	38
---------------------	----

제57조(전자우편 보안)	39
---------------------	----

제58조(비인가 기기 통제)	39
-----------------------	----

제59조(위규자 처리)	40
--------------------	----

제60조(기타)	40
----------------	----

부 칙	40
------------------	-----------

개인정보보호 및 정보보안 기본지침

등록필	2025년 10월 15일	확인자
	지침 제25-16호	조원구

2014년 4월 4일 제정
2015년 10월 7일 개정
2021년 2월 16일 전부개정
2021년 6월 30일 개정
2025년 10월 1일 개정

제1장 총 칙

제1조(목적) 이 지침은 「표준 개인정보 보호지침」(개인정보보호위원회), 「국가 정보보안 기본지침」(국가정보원), 「고용노동부 개인정보 보호지침」 및 「고용노동부 정보보안 기본지침」(고용노동부)에 따라 건설근로자공제회(이하 “공제회”라 한다)의 개인정보보호 및 정보보안 활동에 필요한 사항 규정을 목적으로 한다.

제2조(다른 지침과의 관계) 이 지침에서 정하지 아니한 사항에 대해서는 법률에 특별한 규정이 있는 경우를 제외하고는 제1조(목적)에 따른 지침에서 정하는 바에 따른다.

제3조(정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. “개인정보보호”라 함은 개인정보를 처리함에 있어 개인정보가 분실, 도난, 유출, 위조, 변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 관리적·물리적·기술적 수단을 강구하는 일체의 행위를 말한다.

2. “정보보안” 또는 “정보보호”라 함은 정보통신망 및 정보시스템을 통해 수집, 가공, 저장, 검색, 송·수신되는 정보의 유출, 위·변조, 훼손 등을 방지하기 위하여 관리적·물리적·기술적 수단을 강구하는 일체의 행위를 말한다.
3. “개인정보보호책임자”라 함은 「개인정보 보호법」 제31조, 같은 법 시행령 제32조제2항제1호에 따라 공제회 개인정보의 처리에 관한 업무를 총괄하는 개인정보보호 최고책임자를 말한다.
4. “정보보안책임자”라 함은 공제회 정보통신망과 행정정보, 전자정부 시스템 등의 안전성과 신뢰성 확보를 위해 정보보호 업무를 총괄하는 정보보안 최고책임자를 말한다.
5. “개인정보보호담당관(개인정보보호담당자)”이라 함은 개인정보보호 업무를 총괄하는 부서의 장을 말한다.
6. “정보보안담당관(정보보안관리자)”이라 함은 정보보안 업무를 총괄하는 부서의 장을 말한다.
7. “정보화사업담당관”이라 함은 정보화사업을 추진하는 부서의 장을 말한다.
8. “임직원등”이라 함은 공제회 정규직 근로자(임원, 직원) 이외에 임시직, 파견근로자, 시간제근로자 등을 포함한다.
9. “정보통신망”이라 함은 「지능정보화 기본법」 제2조제8호 및 「전자정부법」 제2조제10호에 따른 정보통신망을 말한다.
10. “내부망”이라 함은 업무 수행을 위하여 인터넷과 별도로 분리하여 구축한 업무 전용(專用) 정보통신망을 말한다.
11. “기관 인터넷망”이라 함은 업무 활용 또는 공개서버 운용을 주(主) 목적으로 인터넷과 연동하여 구축한 정보통신망을 말한다.
12. “상용 인터넷망”이라 함은 기관 인터넷망과 별개로 소속 임직원등이나

민원인 등의 보편적인 편의성을 위하여 인터넷에 연동하여 구축한 정보통신망을 말한다.

13. “개인정보처리시스템” 또는 “정보시스템”이라 함은 「전자정부법」 제2조 제13호에 따른 정보시스템을 말한다.

14. “휴대용 저장매체”라 함은 디스켓·CD·외장형 하드디스크·USB메모리 등 정보를 저장할 수 있는 것으로 PC·서버 등의 정보시스템과 분리할 수 있는 기억장치를 말한다.

15. “업무자료”라 함은 다음 각 목의 어느 하나에 해당하는 것을 말한다.

가. 「전자정부법」 제2조제6호에 따른 행정정보 및 같은 법 제2조제7호에 따른 전자문서

나. 「공공기록물 관리에 관한 법률 시행령」 제2조제2호에 따른 전자기록물

다. 기타 다른 법령에 의하여 임직원등이 직무상 작성·취득하였거나 보유·관리하는 자료로서 전자적으로 처리되어 부호·문자·음성·음향·영상 등으로 표현된 것

16. “비밀” 및 “대외비”라 함은 다음 각 목의 어느 하나에 해당하는 것을 말한다.

가. 국가정보원 「보안업무규정」 제4조에 따라 분류된 비밀

나. 국가정보원 「보안업무규정 시행규칙」 제16조제3항에 따라 분류된 대외비

17. “비공개 업무자료”라 함은 비밀 및 대외비를 제외한 업무자료 중에서 다음 각 목의 어느 하나에 해당하는 자료 또는 정보를 말한다.

가. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따른 비공개 대상 정보

나. 국회 또는 지방의회 요구에 따라 작성 또는 취득한 자료

다. 가목에 따른 비공개 대상 정보의 주요 내용이 기술된 문장 또는 문구

18. “공개 업무자료”라 함은 업무자료 중에서 비밀 및 대외비와 비공개 업무자료를 제외한 모든 자료 또는 정보를 말한다.
19. “정보통신실”이라 함은 서버·스위치·라우터·교환기 등 전산 및 통신장비 등이 설치·운용되는 장소 또는 전산실·통신실·데이터센터 등을 말한다.
20. “개인정보보호시스템” 또는 “정보보호시스템”이라 함은 정보의 수집, 가공, 저장, 검색, 송신, 수신 중 발생할 수 있는 정보의 훼손, 변조, 유출 등을 방지하기 위한 관리적·기술적 수단을 말한다.
21. “개별사용자”라 함은 정보통신망 또는 정보시스템에 대한 접근 또는 사용 허가를 받은 임직원등과 계약에 의하여 정보통신망 또는 정보시스템에 대한 접근 또는 사용 허가를 받은 사람을 말한다.
22. “상급기관”이라 함은 고용노동부와 국가정보원을 말한다.

제4조(개인정보 보호 원칙) ① 임직원등은 개인정보 처리 시 목적을 명확하게 하여야 하고 그 목적에 필요한 범위에서 최소한의 개인정보만을 적법하고 정당하게 수집하여야 한다.

- ② 임직원등은 개인정보의 처리 목적에 필요한 범위에서 적합하게 개인정보를 처리하여야 하며, 그 목적 외의 용도로 활용하여서는 아니 된다.
- ③ 임직원등은 개인정보의 처리 목적에 필요한 범위에서 개인정보의 정확성과 최신성을 유지하도록 하여야 하고, 개인정보를 처리하는 과정에서 고의 또는 과실로 부당하게 변경 또는 훼손되지 않도록 하여야 한다.
- ④ 임직원등은 개인정보의 처리 방법 및 종류 등에 따라 정보주체의 권리가 침해 받을 가능성과 그 위험 정도를 고려하여 그에 상응하는 적절한 관리적·기술적 및 물리적 보호조치를 통하여 개인정보를 안전하게 관리하여야 한다.

- ⑤ 임직원등은 개인정보 처리방침 등 개인정보의 처리에 관한 사항을 공개하여야 하며, 열람청구권 등 정보주체의 권리가 보장될 수 있도록 합리적인 절차와 방법 등을 마련하여야 한다.
- ⑥ 임직원등은 개인정보의 처리 목적에 필요한 범위에서 적법하게 개인정보를 처리하는 경우에도 정보주체의 사생활 침해를 최소화하는 방법으로 개인정보를 처리하여야 한다.
- ⑦ 임직원등은 개인정보를 적법하게 수집한 경우에도 익명에 의하여 업무 목적을 달성할 수 있으면 개인정보를 익명으로 처리하여야 한다.
- ⑧ 임직원등은 관계 법령에서 규정하고 있는 책임과 의무를 준수하고 실천함으로써 정보주체의 신뢰를 얻기 위하여 노력하여야 한다.

제5조(적용범위) 이 지침은 공제회 개인정보보호 및 정보보안 업무에 적용한다.

제6조(책무) ① 이사장은 개인정보와 업무자료 및 정보통신망을 보호하기 위하여 보안대책을 수립·시행하여야 하며 개인정보보호 및 정보보안에 대한 책임을 진다.

② 이사장은 제1항에 따른 책임을 내부규정에 따라 개인정보보호책임자 및 정보보안책임자에게 위임할 수 있다.

제2장 개인정보보호

제1절 개인정보보호책임자 및 내부관리계획

제7조(개인정보보호책임자의 지정 및 역할) ① 경영전략본부장은 위임전결 규정에 따라 발령과 동시에 개인정보보호책임자가 된다.

② 개인정보보호책임자는 다음 사항을 총괄한다.

1. 개인정보 보호 관련 계획의 수립 및 시행
2. 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선
3. 개인정보 처리와 관련한 불만의 처리 및 피해 규제
4. 개인정보 유출 및 오용·남용 방지를 위한 내부통제시스템의 구축
5. 개인정보 보호 교육 계획의 수립 및 시행
6. 개인정보파일의 보호 및 관리 총괄
7. 개인정보 보호법 제30조에 따른 개인정보 처리방침의 수립·변경 및 시행
8. 개인정보 보호 관련 자료의 관리 총괄
9. 처리 목적이 달성되거나 보유기간이 지난 개인정보의 파기 총괄
10. 개인정보 처리 위탁 업무 총괄
11. 개인영상정보의 처리에 관한 업무 총괄
12. 개인정보취급자에 대한 관리·감독 총괄
13. 개인정보처리시스템 안전성 확보를 위한 기술적·관리적·물리적 보호조치 총괄

14. 개인정보 분야별책임자 지휘·감독

15 기타 개인정보 보호를 위하여 필요한 업무

- ③ 개인정보보호책임자는 개인정보 보호와 관련하여 개인정보 보호법 및 다른 관계 법령의 위반 사실을 알게 된 경우에는 즉시 개선조치 하여야 한다.
- ④ 개인정보보호책임자는 개인정보 보호업무를 위하여 개인정보 보호조직을 구성 및 운영하여야 한다.
- ⑤ 개인정보보호책임자는 공제회 부서의 개인정보 처리현황, 처리체계 등 개인정보보호 실태에 대하여 조사하거나 관계 당사자로부터 보고를 받을 수 있다.

제8조(개인정보보호책임자의 공개) ① 제7조제1항의 개인정보보호책임자가 변경된 경우 변경된 성명과 부서의 명칭, 전화번호 등 연락처를 공개하여야 한다.

- ② 개인정보보호책임자를 공개하는 경우 개인정보 보호와 관련한 고충처리 및 상담을 실제로 처리할 수 있는 연락처를 공개하여야 한다. 이 경우 개인정보 보호책임자와 개인정보보호 업무를 처리하는 보호조직(담당자의 성명, 부서의 명칭, 전화번호 등)의 연락처를 함께 공개할 수 있다.

제9조(개인정보 분야별책임자의 지정 및 역할) ① 지사 및 부서의 장은 임용과 동시에 소관 부서의 개인정보 처리에 관한 업무(이하 “분야별 개인정보 처리 업무”라 한다)를 책임질 개인정보 분야별 책임자가 된다.

- ② 분야별 개인정보 처리 업무는 다음 각 호와 같다.

1. 제7조제2항제1호에 따른 개인정보 보호
2. 개인정보의 처리와 관련한 불만의 처리 및 피해 구제
3. 개인정보의 유출 시 조사, 통지, 신고 및 피해확산 방지방안 수립·시행

4. 개인정보취급자에 대한 교육 및 관리·감독
5. 개인정보처리시스템에 대한 개인정보취급자의 접근권한 설정 및 관리
6. 개인정보파일의 등록·변경 관리
7. 개인정보 보호 관련 자료의 관리
8. 처리목적이 달성되거나 보유기간이 지난 개인정보의 파기
9. 개인정보 처리 위탁 업무 관리
10. 개인영상정보의 처리에 관한 업무
11. 개인정보취급자에 대한 관리·감독
12. 개인정보처리시스템 안전성 확보를 위한 기술적·관리적·물리적 보호조치
13. 그 밖에 소관업무 관련 개인정보 보호에 관한 사항 관리·감독 및 개인정보 보호책임자가 명한 사항

제10조(개인정보 내부관리계획 수립 및 시행) ① 개인정보보호책임자는 개인정보 보호와 관련한 법령 및 규칙 등을 준수할 수 있도록 내부관리계획을 수립·시행하여야 한다.

② 개인정보보호책임자는 법령의 개정 등 내부관리계획에 중요한 영향이 있는 경우 이를 즉시 반영하여야 하며 그 이력을 보관·관리하여야 한다.

③ 개인정보보호책임자는 내부관리계획을 임직원등에게 알림으로써 이를 준수하도록 하여야 한다.

제11조(연도 추진계획 수립) 개인정보보호책임자는 매년 「연도 개인정보보호 업무 추진계획」을 수립·시행하여야 한다.

제12조(실태점검) ① 개인정보보호책임자는 연1회 이상 내부관리계획의 이행실태 점검을 실시하여야 한다.

② 개인정보보호책임자는 지사 및 부서를 대상으로 연 1회 이상의 개인정보 처리 실태점검을 실시할 수 있다.

제13조(개인정보보호 교육) ① 개인정보보호책임자는 개인정보보호 교육계획을 수립하여 연1회 이상 임직원등을 대상으로 교육(온라인 교육을 포함한다)을 실시하여야 한다.

② 제1항에 따라 모든 임직원등은 특별한 사유가 없는 한 연1회 이상 개인정보 보호 교육을 이수하여야 한다.

③ 개인정보 보호책임자는 개인정보보호 관련 법규 위반 등의 가능성이 있다고 판단되는 경우, 해당 임직원에게 추가적인 교육을 실시할 수 있다.

제2절 개인정보 처리방침

제14조(개인정보 처리방침의 기재사항) 개인정보보호책임자는 개인정보 보호법 제30조제1항 및 같은 법 시행령 제31조제1항에 따라 다음 각 호의 사항을 포함하여 개인정보 처리방침을 작성하여야 한다.

1. 개인정보의 처리 목적
2. 개인정보의 처리 및 보유 기간
3. 개인정보의 제3자 제공에 관한 사항(해당하는 경우에만 정한다)
4. 개인정보의 파기절차 및 파기방법
5. 개인정보처리의 위탁에 관한 사항(해당하는 경우에만 정한다)
6. 정보주체와 법정대리인의 권리·의무 및 그 행사방법에 관한 사항
7. 개인정보보호책임자의 성명 또는 개인정보 보호업무 및 고충사항을 처리하는

부서의 명칭과 전화번호 등 연락처

8. 인터넷 접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치·운영 및 그 거부에 관한 사항(해당하는 경우에만 정한다)
9. 처리하는 개인정보의 항목
10. 개인정보의 안전성 확보조치에 관한 사항
11. 정보주체의 권익침해에 대한 구제방법
12. 개인정보의 열람청구를 접수·처리하는 부서
13. 개인정보의 추가적인 이용·제공의 기준(해당하는 경우에만 정한다) <개정 '21. 6. 30>
14. 개인정보 처리방침의 변경에 관한 사항 <개정 '21. 6. 30>
15. 민감정보의 공개 가능성 및 비공개를 선택하는 방법(해당하는 경우에만 정한다)
16. 가명정보의 처리 등에 관한 사항(해당하는 경우에만 정한다)

제15조(개인정보 처리방침의 공개) ① 개인정보보호책임자는 개인정보 보호법 제30조제2항에 따라 개인정보 처리방침을 인터넷 홈페이지를 통해 지속적으로 게재하여야 한다.

② 제1항에 따라 인터넷 홈페이지에 게재하는 경우 “개인정보 처리방침”이라는 명칭을 사용하되, 글자 크기, 색상 등을 활용하여 다른 고지사항과 구분함으로써 정보주체가 쉽게 확인할 수 있도록 하여야 한다.

제16조(개인정보 처리방침의 변경) ① 개인정보보호책임자는 법령의 개정 등 개인정보 처리방침에 중요한 영향이 있는 경우 이를 즉시 반영하여야 하며 그 이력을 보관·관리하여야 한다.

② 개인정보 처리방침을 변경하는 경우에는 변경 및 시행의 시기, 변경된 내용을 지속적으로 공개하여야 하며, 변경된 내용은 정보주체가 쉽게 확인할 수 있도록 변경·후를 비교하여 공개하여야 한다.

제3장 정보보안

제17조(정보보안책임자 운영) ① 경영전략본부장은 위임전결규정에 따라 발령과 동시에 정보보안책임자가 된다.

② 정보보안책임자는 다음 사항을 총괄한다.

1. 정보보안 정책의 수립·조정
2. 사이버보안시스템 운영 및 위협 분석·대응 등
3. 기관 정보보호 업무 관리·감독
4. 정보통신망 보안강화 대책
5. 적정 정보보안 예산 및 인력 확보
6. 기타 정보보안 총괄업무

제18조(정보보안담당관 운영) ① 정보보안 업무를 담당하는 부서의 장은 발령과 동시에 정보보안담당관이 된다.

② 정보보안담당관은 정보보안책임자의 업무를 보좌한다.

③ 정보보안담당관의 기본활동은 다음 각 호와 같다.

1. 정보보안 정책·계획의 수립·시행 및 정보보안내규 제·개정
2. 정보보안 전담조직 관리, 전문인력 및 관련예산 확보
3. 정보화사업 보안성 검토 및 보안적합성 검증 총괄
4. 정보통신실, 정보통신망 현황자료 등에 관한 보안관리 총괄
5. 정보통신시설 및 기기 보호

6. 사이버공격 대응훈련 및 평가 총괄
7. 보안관제, 사고대응 및 정보협력 업무 총괄
8. 정보보안교육 및 ‘사이버보안진단의 날’ 계획 수립·시행
9. 기관 정보보안감사 및 정보보안업무 감독
10. 지사 및 부서의 분임정보보안담당관 업무 감독
11. 그 밖에 정보보안과 관련한 사항

제19조(분임정보보안담당관 운영) ① 지사 및 부서의 장은 임용과 동시에 분임정보보안담당관이 된다.

② 정보보안담당관은 제18조제3항 각 호에 해당하는 업무를 수행함에 있어 필요한 경우 해당 업무의 일부를 부서 분임정보보안담당관에게 위임할 수 있다.

③ 분임정보보안담당관의 기본활동은 다음 각 호와 같다.

1. 소속 부서의 정보통신망과 정보시스템의 보안취약 여부 확인
2. 소속 부서의 정보보안교육
3. 그 밖에 소속 부서의 정보보안과 관련한 사항

제20조(연도 추진계획 수립) 정보보안책임자는 매년 「연도 정보보안업무 추진 계획」을 수립·시행하여야 한다.

제21조(정보보안감사) ① 정보보안담당관은 정보보안업무 및 활동을 조사·점검하기 위하여 연1회 이상 정보보안감사를 실시하여야 하며, 이를 위하여 감사의 방향, 중점사항 등을 일반보안 및 감찰업무 수행 부서와 협의할 수 있다.

- ② 정보보안담당관은 정보보안감사 이외에 정보보안업무 수행에 필요한 경우 지사 및 본회 부서를 대상으로 정보보안 점검 방문을 실시할 수 있다.

제22조(정보보안 교육) ① 정보보안책임자는 정보보안에 대한 경각심을 제고하기 위하여 정보보안 교육계획을 수립하여 연1회 이상 임직원등을 대상으로 교육(온라인 교육을 포함한다)을 실시하여야 한다.

- ② 제1항에 따라 모든 임직원등은 특별한 사유가 없는 한 연1회 이상 정보보안 교육을 이수하여야 한다.

- ③ 정보보안책임자는 정보보안담당관, 분임정보보안담당관 및 정보보안 담당 직원의 업무 전문성을 제고하고 소속 임직원등의 정보보안 지식을 함양하기 위하여 전문기관의 교육 이수나 학술회의 참가 등을 장려하여야 한다.

제23조(사이버보안진단의 날) 정보보안담당관은 정보통신망과 정보시스템의 보안취약 여부 확인을 위해 매월 1회 보안진단을 실시하여야 한다.

제4장 정보화사업 보안

제1절 사업 계획

제24조(보안책임) ① 정보통신망 또는 정보시스템을 개발·구축·운영·유지 보수하는 사업(이하 “정보화사업”이라 한다)을 담당하는 정보화사업담당관은 해당 정보화사업에 대한 보안 관리를 수행하여야 한다.

② 정보화사업을 추진하는 정보화사업담당관은 정보화사업에 대한 보안관리 책임을 지고 관리·감독하여야 한다.

③ 정보보안담당관은 각종 정보화사업과 관련한 보안대책의 적절성을 평가하고 정보화사업 수행 전반에 대하여 보안대책의 이행여부를 점검하여 필요한 경우 정보화사업을 담당하는 부서의 장에게 시정을 요구할 수 있다.

제25조(보안대책 수립) 정보통신망 또는 정보시스템을 구축·운영하기 위한 정보화사업 계획을 수립하는 정보화사업담당관은 정보보안담당관과 협의하여 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 보안관리체계(조직, 인원 등) 구축 등 관리적 보안대책
2. 설치·운영장소 보안관리 등 물리적 보안대책
3. 정보통신망 또는 정보시스템의 구성요소별 기술적 보안대책
4. 암호자재, 상용 암호모듈 및 정보보호시스템 도입·운영계획
5. 긴급사태 대비 및 재난복구 계획
6. 용역업체 작업장소에 대한 보안대책

7. 누출금지정보 보안관리 방안

8. 원격지, 온라인 개발 또는 유지보수가 필요한 경우 상황에 따른 물리적·기술적·관리적 보안대책

제26조(제안요청서 기재사항) ① 정보화사업담당관은 용역업체에 정보화사업을 발주하기 위하여 제안요청서를 작성할 경우 다음 각 호의 사항을 포함하여야 한다.

1. 용역업체 작업장소에 대한 보안요구사항

2. 누출금지정보 목록

3. 원격지, 온라인 개발 또는 유지보수가 필요한 경우 상황에 따른 물리적·기술적·관리적 보안요구사항

4. 용역업체가 누출금지정보를 제외한 소프트웨어 산출물을 제3자에게 제공하고자 할 경우 발주자의 승인절차

② 제1항제2호에 따른 누출금지정보 목록을 작성할 경우 다음 각 호의 사항을 포함하여야 한다.

1. 공제회 정보시스템 내·외부 IP주소 현황

2. 정보시스템 구성 현황 및 정보통신망 구성도

3. 개별사용자의 계정·비밀번호 등 정보시스템 접근권한 정보

4. 정보통신망 또는 정보시스템 취약점 분석·평가 결과물

5. 정보화사업 용역 결과물 및 관련 프로그램 소스코드

6. 암호자재 및 정보보호시스템 도입·운용 현황

7. 정보보호시스템 및 네트워크장비 설정 정보
8. 「공공기관의 정보공개에 관한 법률」 제9조제1항에 따라 비공개 대상 정보로 분류된 해당 기관의 내부분서
9. 「개인정보보호법」 제2조제1호에 따른 개인정보
10. 제3조제16호가목에 따른 비밀 및 제3조제16호나목에 따른 대외비
11. 그 밖에 공제회 외부에 공개가 불가하다고 판단한 자료

제2절 보안성 검토

제27조(검토 시기 및 절차) ① 정보화사업담당관은 정보화사업을 수행하고자 할 경우 정보화사업과 관련한 보안대책의 적절성을 평가하기 위하여 사업 계획 단계(사업 공고 전)에서 보안성 검토 절차를 이행하여야 한다.

② 정보보안담당관은 제1항에 따른 보안성 검토를 자체적으로 실시하거나 상급 기관의 장에게 의뢰하여야 한다.

③ 보안성 검토는 서면 검토(현장 확인을 병행 실시할 수 있다)를 원칙으로 하며 제2조(다른 지침과의 관계)를 준용한다.

제28조(검토 대상) 다음 각 호에 해당하는 정보화사업에 대하여는 상급기관의 장에게 보안성 검토를 의뢰하여야 한다. 다만, 제12호부터 제16호까지 해당하는 경우 정보보안담당관이 자체적으로 보안성 검토를 실시할 수 있다.

1. 100만명 이상의 개인에 대한 「개인정보 보호법」 상 민감정보 또는 고유식별 정보를 처리하는 정보시스템 구축
2. 내부망 또는 폐쇄망을 인터넷 또는 다른 정보통신망과 연동하는 사업

3. 통합데이터센터·보안관제센터 구축
4. 제37조에 따른 공제회 내부망과 인터넷망을 분리하는 사업
5. 제48조제4항에 따른 원격근무시스템 구축
6. 제38조에 따른 자체 클라우드컴퓨팅 구축 또는 민간 클라우드컴퓨팅 서비스를 이용하는 사업
7. 홈페이지 및 웹메일 등 웹기반 정보시스템 구축
8. 인터넷전화시스템 구축
9. 다른 기관의 정보통신망 또는 정보시스템과 연동하여 정보의 소통 또는 서비스를 제공하는 정보시스템 구축
10. 인터넷과 분리된 임직원등의 인사·복지관리 등의 목적을 위한 정보시스템 구축
11. 기존 분리된 내부망과 인터넷망간 자료전송시스템 구축 등 후속사업
12. 공제회 정보통신망 또는 정보시스템과 분리된 별도의 영상회의시스템 구축
13. 인터넷과 분리된 CCTV 등 영상정보처리기기 구축
14. 백업시스템 구축
15. 대민(對民) 콜센터시스템 구축
16. 기타 이사장이 필요하다고 판단하는 정보통신망 또는 정보시스템 구축

제29조(검토 생략) ① 정보보안담당관은 다음 각 호에 해당하는 정보화사업에 대하여 보안성 검토 절차의 이행을 생략할 수 있다. 이 경우 관련 매뉴얼·가이드라인 등을 준수하는 등 자체 보안대책을 수립·시행하여야 한다.

1. 제27조 및 제28조에 따른 보안성 검토 대상에 해당하지 아니하는 단순 장비·물품 도입

2. 제27조 및 제28조에 따른 보안성 검토를 거쳐 완료한 정보화사업에 대하여 정보통신망 구성을 변경하지 아니하는 범위 내에서 다음 각 목의 사항을 포함한 후속운영·유지보수·컨설팅(단일 회선의 이중화는 본 호를 적용함에 있어 정보통신망 구성의 변경이 아닌 것으로 본다)

가. 서버·스토리지·네트워크장비 등 장비 노후화로 인한 단순 장비 교체

나. 전화기·무전기·CCTV 등 통신·영상기기의 노후화로 인한 단순 장비 교체

다. 기존 운용하던 정보보호시스템을 동일한 보안기능을 보유한 다른 정보보호시스템으로 교체

3. 다년도에 걸쳐 계속되는 사업으로써 사업 착수 당시 보안성 검토를 완료한 후 사업 내용의 변동 없이 계속 추진하는 운영·유지사업

4. PC·프린터 및 상용 소프트웨어 등 단순 제품 교체

② 제1항제2호부터 제4호까지에 해당하는 정보화사업을 수행할 경우 기존 보안성 검토결과를 준수하여야 한다.

제30조(제출 문서) 정보화사업담당관은 제27조 및 제28조에 따라 보안성 검토를 의뢰할 경우 다음 각 호의 사항이 포함된 문서를 제출하여야 한다.

1. 사업계획서(사업목적 및 추진계획을 포함한다)

2. 제안요청서

3. 정보통신망 구성도(필요시 IP주소체계를 추가한다)

4. 자체 보안대책

제31조(검토결과 조치) ① 제27조 및 제28조에 따라 정보화사업 보안성 검토 결과를 통보받은 정보화사업담당관은 검토결과를 반영하여 보안대책을 보완하여야 한다.

- ② 정보보안담당관등은 제1항에 따른 보안성 검토결과 반영여부를 확인하기 위하여 현장 점검을 실시할 수 있다.
- ③ 정보화사업을 추진하는 정보화사업담당관은 정보보안담당관과 협의하여 제1항에 따른 보안 대책을 해당 정보화사업에 반영하여야 한다.

제3절 계약 및 사업수행

제32조(계약 특수조건) ① 정보화사업담당관은 정보통신망 또는 정보시스템 구축 및 유지보수 등의 계약 이행과정에서 다음 각 호의 사항의 행위를 금지하는 내용의 계약 특수조건을 계약서에 명시하여야 하며, 계약기간(하자 보증기간을 포함한다) 내에 발생한 보안약점 등에 대해서는 계약업체로 하여금 개선 조치하도록 하여야 한다.

1. 정보통신망 또는 정보시스템에 허가 없이 접속
2. 무단으로 정보를 수집할 수 있는 비(非)인가 프로그램의 설치
3. 제1호 내지 2호에 해당하는 행위에 악용될 수 있는 약점을 고의로 생성 또는 방치하는 행위

② 정보화사업담당관은 필요한 경우 계약업체로부터 제1항과 관련한 행위가 없다는 대표자 명의의 확인서를 요구할 수 있다.

제33조(용역업체 보안) ① 정보화사업을 발주하는 정보화사업담당관은 다음 각 호의 보안사항을 준수하도록 계약서에 명시하여야 한다.

1. 제26조제1항 각 호에 따른 제안요청서에 포함된 사항

1의2. 원격지, 온라인 개발 또는 유지보수를 허용할 경우 상황에 따른 물리적·기술적·관리적 보안 준수사항

2. 소프트웨어 개발보안에 필요한 사항
 3. 사업 참여인원의 보안관련 준수사항과 위반할 경우 손해배상 책임에 관한 사항
 4. 사업 수행과 관련한 보안교육, 보안점검 및 사업기간 중 참여인원 임의교체 금지
 5. 정보통신망 구성도·IP주소 현황 등 업체에 제공하는 자료는 자료 인계 인수대장을 비치하여 보안조치 후 인계·인수하고 무단 복사 및 외부반출 금지
 6. 업체의 노트북·휴대용 저장매체 등 관련 장비는 반출·입시마다 악성코드 감염여부, 누출금지정보 무단 반출여부 등 점검
 7. 사업 종료시 업체의 노트북·휴대용 저장매체 등 관련 장비는 저장자료 복구가 불가하도록 완전 삭제 또는 저장매체 반납
 8. 사업 종료 시 누출금지정보 전량 회수
 9. 그 밖에 보안관리가 필요하다고 판단되거나 보안조치를 권고하는 사항
- ② 정보화사업담당관은 비밀 및 중요 용역사업을 수행할 경우 용역업체 참여 인원이 다음 각 호에 해당되는 사실을 알게 된 경우 교체를 요구하여야 한다.
1. 「국가공무원법」 제33조제3호부터 제6의4호까지에 해당하는 사람
 2. 「국가를 당사자로 하는 계약에 관한 법률」 제27조제1항 각 호의 행위를 한 사람
- ③ 정보화사업담당관은 다음 각 호에 따른 보안 준수사항의 이행여부를 정기 또는 수시로 점검(불시 점검을 포함한다)하고 미비점을 발견한 경우 용역업체로 하여금 시정 조치하도록 하여야 한다. 이 경우 점검한 후 그 결과를 정보보안 담당관에게 통보하여야 한다.
1. 제1항에 따라 계약서에 명시된 보안 준수사항
 2. 제34조에 따른 발주기관내 작업장소 보안 준수사항

3. 제35조에 따른 원격지 개발보안 및 제36조에 따른 원격지에서의 온라인 개발시 보안 준수사항
 4. 제43조에 따른 정보시스템 유지보수 및 제44조에 따른 지정 단말기를 통한 온라인 유지보수 시 보안 준수사항
- ④ 정보보안담당관은 용역업체 보안관리 실태 점검을 실시할 수 있으며, 필요한 경우 상급기관의 장에게 지원을 요청할 수 있다.
 - ⑤ 정보보안담당관은 제3항 및 제4항에 따른 점검 결과, 용역업체 보안대책 준수가 미흡하고 시정조치가 어렵다고 판단할 경우 제35조에 따른 원격지 개발, 제36조에 따른 원격지에서의 온라인 개발 또는 제44조에 따른 지정 단말기를 통한 온라인 유지보수 허가를 취소할 수 있다.
 - ⑥ 정보보안담당관은 제36조에 따른 원격지에서의 온라인 개발, 제44조에 따른 지정 단말기를 통한 온라인 유지보수를 허용하고자 할 경우, 용역업체의 온라인 접속을 통제하기 위한 온라인 용역 통제시스템을 구축·운영하여야 한다.
 - ⑦ 그 밖에 용역업체 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」을 준수하여야 한다.

제34조(발주기관내 작업장소 보안) ① 정보화사업담당관은 발주기관내(기관장이 임차한 외부 사무실을 포함한다) 용역업체 작업장소를 설치할 경우 보안 통제가 가능한 공간을 마련 운영하여야 한다.

- ② 발주기관내 용역업체 작업장소에 설치 운영하는 정보통신망은 발주기관의 정보통신망과 분리 구성하여야 한다. 다만, 용역업체가 사업 수행을 위하여 발주기관 정보시스템 이용이 불가피할 경우에는 필요한 정보시스템에 한해 지정된 단말기로부터의 제한적 접근을 허용하는 등 보안대책을 수립·시행하여야 하며, 이 경우 내부망 정보시스템에 대한 접근 허용에 관하여는 정보보안책임자의 승인을 받아야 한다.

- ③ 작업장소내 정보시스템은 용역사업 수행을 위해 필요한 경우 해당 정보화사업 담당관의 보안통제 하에 인터넷에 연결할 수 있다. 다만, 제2항 단서에 따른 발주기관 정보시스템 접근용 단말기의 경우에는 인터넷 연결을 금지한다.
- ④ 용역업체가 발주기관내 작업장소에서 개발 작업을 수행하더라도 개발용 서버가 민간 클라우드컴퓨팅서비스를 이용하는 등으로 원격지에 위치할 경우 제35조에 따른 원격지 개발로 간주하고 제35조제1항에 따른 보안대책을 수립·시행하여야 한다.

제35조(원격지 개발보안) ① 용역업체가 발주기관 이외 장소(이하 “원격지”라 한다)에서 개발 작업(유지보수는 제외한다)을 수행하고자 요청할 경우 제26조 제1항제1호에 따른 용역업체 작업장소에 대한 보안요구사항 등을 포함한 관리적·기술적 보안대책을 수립·시행하여야 한다. 이 경우 정보화사업담당관은 보안대책을 수립한 후 정보보안담당관의 승인을 받아야 한다.

- ② 원격지내 정보시스템은 개발 작업을 위하여 필요한 경우 해당 정보화사업 담당관의 보안통제 하에 인터넷에 연결할 수 있다.

제36조(원격지에서의 온라인 개발) 제35조에 따른 원격지 개발에서 정보보안 담당관이 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한하여, 용역업체에게 원격지에서 인터넷을 통해 발주기관 정보시스템에 온라인 접속한 상태의 개발 작업을 허용할 수 있다.

1. 지정된 단말기에서만 접속 및 해당 단말기에 대한 접근인원 통제
2. 지정 단말기는 제3호에 따른 온라인 용역 통제시스템 접속 전용(專用)으로 운용하고 다른 목적의 인터넷 접속은 차단
3. 발주기관내 온라인 용역 통제시스템을 경유하여 개발에 필요한 정보시스템에 접속하는 등 소통구간 보호·통제

4. 접속사실이 기록된 로그기록을 1년 이상 보관
5. 계약 시행일로부터 종료 후 30일이 경과하는 날까지의 기간 중에 발주기관, 고용노동부장관 및 국가정보원장의 정기 또는 수시 보안점검(불시 점검을 포함한다) 수검
6. 기타 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」에서 제시된 온라인 개발에 관련된 보안대책의 준수

제5장 정보통신망 및 정보시스템 보안

제1절 정보통신망 보안

제37조(내부망·인터넷망 분리) ① 공제회는 내부망과 기관 인터넷망을 분리·운영(이하 “망분리”라 한다)하여야 한다.

② 내부망과 기관 인터넷망을 분리·운영하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 침입차단·탐지시스템 설치 등 비(非)인가자 침입 차단대책
2. 네트워크 접근관리시스템 설치 등 비(非)인가 장비의 내부망 접속 차단대책
3. 내부망 정보시스템의 인터넷 접속 차단대책
4. 내부망과 기관 인터넷망간 안전한 자료전송 대책
5. 기타 국가정보원장이 배포한 「국가·공공기관 업무전산망 분리 및 자료전송 보안가이드라인」에서 제시하는 보안대책

③ 정보보안담당관은 정보통신망 및 정보시스템에 구축·운영 시 부여되는 IP주소를 체계적으로 관리하여야 하며 비(非)인가자로부터 내부망을 보호하기 위하여 네트워크주소변환기(NAT)를 이용하여 사설 IP주소체계를 구축·운영하여야 한다. 또한 IP주소별로 정보시스템 접속을 통제하여 비(非)인가 기기에 의한 내부망 접속을 차단하여야 한다.

④ 정보보안담당관은 분리된 내부망과 기관 인터넷망간 자료전송을 위한 접점이 불가피한 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 침입차단·탐지시스템 설치·운용

2. 내부망과 기관 인터넷망간 점점 최소화

3. 내부망과 기관 인터넷망간 일방향 전송장비 등을 이용한 자료전송체계를 구축·운영하고 원본파일은 3개월 이상, 전송기록은 6개월 이상 유지

4. 정기적으로 전송실패 기록을 확인하고 악성코드 유입여부 등 점검

5. 내부망 자료를 기관 인터넷망으로 전송할 경우 부서 분임정보보안담당관 또는 결재권자의 사전 또는 사후 승인절차 마련

⑤ 제1항에도 불구하고 예산 부족 등 사유로 부득이한 경우 내부망과 기관 인터넷망을 분리하지 아니할 수 있다. 이 경우 정보보안담당관은 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 정보시스템 및 개별사용자 PC 영역 등에 대한 접근 통제대책

2. 인터넷 PC의 악성코드 감염 최소화를 위한 인터넷 사용 통제대책

3. 인터넷 PC의 악성코드 감염에 따른 내부망으로의 피해확산 차단대책

4. 사이버공격 탐지·대응 등 안전한 업무환경을 위한 보호대책

⑥ 정보보안담당관은 내부망과 기관 인터넷망의 IP주소 현황을 정기적으로 확인하고 갱신하여야 한다.

제38조(클라우드컴퓨팅 보안) ① 「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」 제12조에 따라 클라우드컴퓨팅을 자체 구축·운영하고자 할 경우 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안 가이드라인」에 명시된 기관 자체 클라우드컴퓨팅 구축 보안기준에 따라 보안대책을 수립·시행하여야 한다.

② 민간 클라우드컴퓨팅서비스를 이용하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 국내에 위치한 정보시스템에 데이터가 저장되는 서비스로서 일반 이용사용 서비스 영역과 물리적으로 분리되어 제공되는 서비스 영역(이하 “공공 전용(專用) 민간클라우드”라 한다)에 한하여 활용
 2. 과학기술정보통신부장관이 고시한 「클라우드컴퓨팅서비스 정보보호에 관한 기준」에 부합하는 서비스 선정
 3. 국가정보원장이 배포한 「국가·공공기관 클라우드 컴퓨팅 보안 가이드라인」에서 제시하는 민간 클라우드컴퓨팅서비스 이용 보안기준 및 행정안전부장관이 배포한 「행정·공공기관 민간 클라우드 이용 가이드라인」에 따른 절차 이행
- ③ 공제회 내부망과 연동된 공공 전용(專用) 민간클라우드는 이 지침을 적용함에 있어 공제회 내부망으로 본다.
- ④ 공제회 기관 인터넷망과 연동된 공공 전용(專用) 민간클라우드는 이 지침을 적용함에 있어 공제회 인터넷망으로 본다.

제39조(보안·네트워크장비 보안) ① 공제회가 침입차단·탐지시스템, 스위치·라우터 등 기관 정보통신망 구성 또는 정보보안 정책 전반에 영향을 미치는 보안·네트워크장비를 설치·운용하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 물리적으로 안전한 장소에 설치하여 비(非)인가자의 무단접근 통제
2. 콘솔에서 관리함을 원칙으로 하되, 다음 각 목의 경우 청사 내 지정 단말기로부터의 접속·관리 허용

가. 장비 관리자의 접속

나. 제34조제2항 단서에 따른 발주기관내 용역업체 작업장소에서의 접속

3. 최초 설치할 경우 디폴트(default) 계정은 삭제하거나 변경 사용하고 장비 관리를 위한 관리자 계정을 별도로 생성·운영

4. 불필요한 서비스 포트와 개별사용자 계정은 차단 및 삭제
5. 펌웨어 무결성과 컴퓨터 운영체제·소프트웨어의 취약점 및 버전 업데이트 여부를 정기적으로 점검하고 최신 버전으로 유지
- ② 보안·네트워크장비 관리자는 로그기록을 1년 이상 유지하여야 하고 비(非)인가자의 접속여부를 정기적으로 점검하여 그 결과를 정보보안담당관에게 통보하여야 한다.
- ③ 보안·네트워크장비 관리자는 침입차단·탐지시스템의 침입차단·탐지규칙(rule)의 생성 근거를 유지하고 정기적으로 필요성 여부를 점검·갱신하여야 한다.

제40조(인터넷전화 보안) ① 인터넷전화시스템을 구축·운영하거나 민간 인터넷전화 사업자망을 이용하고자 할 경우 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 한국정보통신기술협회(TTA) verified ver.4 이상 보안규격으로 인증받은 행정기관용 인터넷전화시스템 설치·운영
2. 인터넷전화기에 대한 장치 및 사용자 인증
3. 제어신호 및 통화내용 등 데이터 암호화
4. 인터넷전화망과 다른 정보통신망과의 분리
5. 인터넷전화 전용(專用) 침입차단시스템 등 정보보호시스템 설치·운영
6. 백업체제 구축
- ② 민간 인터넷전화 사업자망을 이용할 경우 해당 사업자로 하여금 서비스 제공 구간에 대한 보안대책을 수립하도록 하여야 한다.
- ③ 기타 인터넷전화 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 인터넷전화 보안 가이드라인」을 준수하여야 한다.

- 제41조(인터넷 사용제한)** ① 정보보안담당관은 국가비상사태 및 대형 재해·재난의 발생, 사이버공격 등으로부터 정보통신망과 정보시스템의 정상적인 운영을 보장하기 위하여 소속 임직원등에 대한 인터넷 사용을 일부 제한할 수 있다.
- ② 정보보안담당관은 기관 인터넷망의 효율적인 운영 관리 및 악성코드 유입 차단을 위하여 게임·음란·도박·상용메일 등 업무와 관련이 없는 인터넷 이용을 차단하여야 하며, 악성코드 유입 차단을 위하여 필요할 경우 상용 정보통신 서비스의 접속을 제한할 수 있다.

제2절 정보시스템 보안

- 제42조(정보시스템 보안책임)** ① 정보시스템(PC·서버·네트워크장비·정보통신 기기 등을 포함한다)을 도입·운용할 경우 해당 정보시스템에 대하여 관리자 및 관리책임자를 지정·운영하여야 한다.
- ② 정보시스템 관리자 및 관리책임자는 서버·네트워크장비 등 부서가 공동으로 사용하는 정보시스템의 운용·관리에 대한 보안책임을 진다.
- ③ 정보시스템 관리책임자는 정보시스템을 실제 운용하는 부서의 장이 되며 관리책임자는 정보시스템 관리를 위한 대장 등 정보시스템 목록을 수기 또는 전자적으로 작성·관리하여야 한다.
- ④ 정보시스템 관리책임자는 정보시스템 관리대장(전자문서를 포함한다)에 정보시스템의 최종 변경 현황을 유지하여야 하며 정보보안담당관의 요청이 있는 경우 열람하여야 한다.
- ⑤ 정보보안담당관은 정보시스템 운용과 관련하여 보안취약점을 발견하거나 보안대책 수립이 필요하다고 판단하는 경우 개별사용자, 정보시스템 관리자 및 관리책임자에게 개선 조치를 요구할 수 있으며 조치가 완료될 때까지 정보시스템의 운용을 일시 제한할 수 있다.

제43조(정보시스템 유지보수) ① 정보시스템 관리자는 정보시스템의 유지보수와 관련한 절차, 주기, 문서화 등과 관련한 사항을 수립할 경우 다음 각 호의 사항을 고려하여야 한다.

1. 유지보수 인원에 대한 보안서약서 집행, 보안교육 등을 포함한 유지보수 인가 절차를 마련하고 인가된 인원만 유지보수에 참여
2. 결함이 의심되거나 발생한 결함, 예방 및 유지보수에 대한 기록 유지
3. 유지보수를 위하여 정보시스템을 원래 설치장소에서 다른 장소로 이동할 경우 통제수단 마련
4. 유지보수 일시 및 담당자 인적사항, 출입통제 조치사항, 작업수행 내용 등 기록 유지

② 정보시스템 관리자는 용역업체 등이 유지보수와 관련한 장비·도구 등을 제34조제1항에 따른 발주기관내 용역업체 작업장소로 반출·입할 경우 악성코드 감염여부 및 자료 무단 반출여부 확인 등 보안조치를 실시하고 그 결과를 분임정보보안담당관에게 제출하여야 한다.

③ 정보시스템 관리자는 직접 또는 용역업체를 활용하여 정보시스템을 유지 보수할 경우 콘솔 또는 지정된 단말기로부터의 접속만을 허용하여야 한다.

④ 정보시스템 관리자는 소관 정보시스템에 대하여 중요도·가용성 등에 따라 등급을 분류하고 해당 등급에 맞게 정보 보존 및 관리, 장애관리, 보안관리 등을 수행하여야 한다.

제44조(지정 단말기를 통한 온라인 유지보수) ① 제43조제3항에 따른 지정된 단말기를 통해 유지보수를 함에 있어 정보보안담당관이 필요하다고 판단하고 용역업체가 다음 각 호에 따른 보안대책에 서면으로 동의하는 경우에 한하여, 정보시스템 관리자는 용역업체에게 소관 정보시스템에 대하여 인터넷을 통한 온라인 유지보수를 허용할 수 있다.

1. 지정된 장소에 설치된 지정된 단말기에서만 접속 및 해당 단말기에 대한

접근인원 통제

2. 지정 단말기는 제3호에 따른 온라인 용역 통제시스템 접속 전용(專用)으로 운용하고 다른 목적의 인터넷 접속은 차단
 3. 발주기관내 온라인 용역 통제시스템을 경유하여 유지보수 대상 정보시스템에 접속하는 등 소통구간 보호·통제
 4. 접속사실이 기록된 로그기록을 1년 이상 보관
 5. 유지보수 계약 시행일로부터 종료 후 30일이 경과하는 날까지의 기간 중에 발주기관, 고용노동부장관 및 국가정보원장의 정기 또는 수시 보안점검(불시 점검을 포함한다) 수검
 6. 기타 국가정보원장이 배포한 「국가·공공기관 용역업체 보안관리 가이드라인」에서 제시된 온라인 유지보수에 관련된 보안대책의 준수
- ② 기타 정보시스템 온라인 유지보수 보안과 관련한 사항은 제33조(용역업체 보안)를 준용한다.

제45조(서버 보안) ① 서버를 도입·운용하고자 할 경우 사이버공격으로 인한 자료 절취 및 위·변조 등에 대비하여 다음 각 호의 사항을 포함한 보안대책을 수립·시행하여야 한다.

1. 서버 내 저장자료에 대하여 업무별·자료별 중요도에 따라 개별사용자의 접근권한 차등 부여
2. 개별사용자별 자료 접근범위를 서버에 등록하여 인가여부를 식별하도록 하고 인가된 범위 이외 자료 접근통제
3. 서버 운용에 필요한 서비스 포트 이외 불필요한 서비스 포트 제거 및 관리자용 서비스와 개별사용자용 서비스 분리·운용
4. 관리자용 서비스 접속시 특정 IP주소가 부여된 관리용 단말기 지정·운용
5. 서버 설정 정보 및 저장자료에 대한 정기적 백업 실시
6. 데이터베이스에 대하여는 개별사용자의 직접 접속 차단, 개인정보 등 중요

정보 암호화 등 데이터베이스별 보안조치 실시

- ② 서버 관리자는 제1항에 따른 보안대책의 적절성을 수시 확인하여야 하며 연1회 이상 서버 설정 정보와 저장자료의 절취 및 위·변조 가능성 등 보안취약점을 점검·보완하여야 한다.

제46조(공개서버 보안) ① 외부인에게 공개할 목적으로 웹서버 등 공개서버를 구축·운영하고자 할 경우 내부망과 분리된 영역(DMZ)에 설치하여야 한다.

- ② 비(非)인가자의 공개서버 저장자료 절취 및 위·변조, 분산서비스거부(DDoS) 공격 등에 대비하여 침입차단·탐지시스템 및 DDoS 대응장비 설치 등 보안대책을 수립·시행하여야 한다.

- ③ 공개서버 관리자는 비(非)인가자의 공개서버 내 비공개 정보에 대한 무단 접근을 방지하기 위하여 서버에 접근할 수 있는 개별사용자를 제한하고 불필요한 계정은 삭제하여야 한다.

- ④ 공개서버 관리자는 공개서버 서비스에 필요한 프로그램을 개발·시험하기 위하여 사용한 도구(컴파일러 등) 및 서비스와 관계가 없는 산출물은 개발 완료 후 삭제하여야 한다.

- ⑤ 기타 공개서버 보안과 관련한 사항은 제45조(서버 보안)를 준용한다.

제47조(로그기록 유지) ① 정보시스템의 효율적인 통제·관리 및 사고 발생시 추적 등을 위하여 로그기록을 유지·관리하여야 한다.

- ② 제1항에 따른 로그기록에는 다음 각 호의 사항이 포함되어야 한다.

1. 접속자, 정보시스템·응용프로그램 등 접속대상
2. 로그인·오프, 자료의 열람·출력 등 작업 종류 및 시간
3. 접속 성공·실패 등 작업 결과
4. 전자우편 사용 등 외부발송 정보 등

- ③ 정보시스템 관리자는 로그기록을 생성하는 정보시스템의 경우 시간 동기화

프로토콜(NTP) 적용 등을 통해 정확한 기록을 유지하여야 한다.

- ④ 정보시스템 관리자는 로그기록을 정기적으로 점검하고 점검 결과 비(非)인가자의 접속 시도, 자료의 위·변조 및 삭제 등 의심스러운 정황이나 위반한 사실을 발견한 경우 즉시 정보보안담당관에게 통보하여야 한다.
- ⑤ 정보시스템 관리자는 로그기록을 1년 이상 보관하여야 하며 로그기록의 위·변조 및 외부유출 방지대책을 수립·시행하여야 한다.

제48조(원격근무 보안) ① 공제회는 임직원등이 재택근무, 출장지 현장 근무 또는 파견 근무 시 인터넷을 통해 본인 인증을 거쳐 기관 정보시스템에 접속하여 온라인상으로 업무를 수행(이하 “원격근무”라 한다)하게 할 수 있다.

- ② 제1항에 따른 원격근무를 위해 접속할 수 있는 기관 정보시스템은 다음 각 호와 같다.

- 1. 기관 인터넷망에 위치한 서버

- 2. 제37조제2항제4호에 따른 방법을 통해 접속할 수 있는 내부망 서버

- ③ 제1항에 따른 원격근무로 취급할 수 있는 업무자료의 범위는 공개 및 비공개 업무자료로 한다.

- ④ 원격근무를 시행하고자 할 경우 다음 각 호의 사항을 포함한 보안대책이 강구된 정보시스템(이하 “원격근무시스템”이라 한다)을 구축·운영하여야 한다.

- 1. 검증필 암호모듈이 탑재된 정보보호시스템을 사용해 원격근무시스템과 원격근무자의 단말기 간 소통구간 암호화

- 2. 문서 암호화제품(DRM) 사용 등 문서 보호대책 강구

- 3. 원격근무자를 식별·인증하기 위하여 공인인증서, 생체인증 기술 및 일회용 비밀번호 생성기(OTP) 등 보안성을 강화한 사용자 인증방식 적용

- 4. 원격근무자로 하여금 원격근무시스템 접속과정에서 제1호부터 제3호까지의 보안대책을 준수토록 조치

- 5. 원격근무시스템에 대한 보안취약점 정기 점검

- ⑤ 원격근무자는 원격근무용 단말기의 보안을 위하여 다음 각 호의 조치에 적극 협조하여야 한다.
1. 제4항에 따라 제공하는 보안소프트웨어 설치·운영
 2. 사이버공격 등으로 인한 자료유출 사고 발생 시 필요한 점검 및 원격근무용 단말기의 저장자료·이용내역 등의 자료 제출 요청 협력
 3. 원격근무용 단말기의 경우 제54조에 따른 단말기 보안대책 준수
- ⑥ 원격근무 시 원격근무자에게 제5항에 따른 보안조치 등이 포함된 보안서약서를 징구하고 직위·임무에 부합한 정보시스템 접근권한 부여 및 보직변경·퇴직 등 변동사항이 발생시 접근권한 조정 등의 절차를 마련·시행하여야 한다.
- ⑦ 기타 원격근무 보안과 관련한 사항은 국가정보원장이 배포한 「원격업무 통합보안매뉴얼」을 준수하여야 한다.

제3절 자료 보안

제49조(비공개 업무자료 처리) ① 임직원등은 비공개 업무자료를 다음 각 호의 어느 하나에 해당하는 방법으로만 처리하여야 한다.

1. 소속 또는 지급받은 내부망 PC 및 서버에 작성 및 저장·보관
2. 소속 또는 지급받은 휴대용 저장매체에 작성 및 저장·보관
3. 다음 각 목의 어느 하나에 해당하는 수단(이하 “업무자료 공식 소통수단”이라 한다)을 이용한 수·발신 또는 등재·열람

가. 소속 또는 근무중인 기관에서 자체적으로 구축·운용하는 전자우편시스템(이하 “기관 전자우편”이라 한다)

나. 임직원등이 다른 임직원등과 자료를 공유하거나 소통하기 위하여 사용하는 전용(專用) 소프트웨어(이하 “공공 전용(專用) 메신저”라 한다)

다. 국회사무처가 구축·운용하는 의정자료전자유통시스템 등 기관간 업무자료의 소통 또는 공동 활용을 위해 구축한 정보시스템

4. 그 밖에 다른 법규에 따라 허용되는 처리방법

② 임직원등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하는 경우 소속 또는 지급받은 인터넷 PC 또는 출장용 노트북을 이용하여 비공개 업무자료를 처리할 수 있다.

1. 업무자료 공식 소통수단의 발신 또는 등재 기능을 이용하여 제3조제17호다목의 문장 또는 문구 작성

2. 업무자료 공식 소통수단의 수·발신 또는 등재·열람 과정에서의 일시적 저장

③ 임직원등은 제1항에도 불구하고 다음 각 호의 어느 하나에 해당하는 경우 개인이 소유한 PC 등을 이용하여 비공개 업무자료를 처리할 수 있다.

1. 제48조제4항에 따른 원격근무시스템에 접속하여 작성
2. 「감염병의 예방 및 관리에 관한 법률」 제34조제1항에 따른 감염병 위기관리 조치 등 대규모 질병·재난 발생 등 특별한 사정으로 재택근무를 명받았으나 소속 또는 근무중인 기관에 제48조제4항에 따른 원격근무시스템이 구축되지 아니한 경우
3. 국민의 생명·신체, 국가안보 및 공공의 안전 등을 위하여 긴급히 작성, 저장, 수·발신이 필요하다고 소속 또는 근무중인 기관의 장이 인정하는 경우
- ④ 임직원등은 제2항 및 제3항까지에 따라 작성·저장한 비공개 업무자료는 활용이 종료된 후에는 삭제하여야 한다.

제50조(비공개 업무자료 유출방지) ① 공제회는 임직원등이 제49조에 따른 비공개 업무자료 처리 절차 준수하도록 보안체계를 구축·운영하여야 한다.

- ② 임직원등에 의한 비공개 업무자료 유출방지를 위하여 전용(專用) 메신저 또는 내부 전자메일 등 이용을 활성화할 수 있도록 노력하여야 한다.

제51조(공개 업무자료 처리) 임직원등은 관계 법규에 위배되지 않는 범위 내에서 인터넷 PC나 개인이 소유한 PC·휴대용 저장매체 등을 이용하여 공개 업무자료를 처리할 수 있다.

제52조(홈페이지 등 게시자료 보안) ① 부서 분임정보보안담당관은 해당 부서에서 홈페이지 등에 업무자료를 게시하고자 할 경우 자료 내용을 사전 검토하여 비공개 업무자료가 게시되지 아니하도록 하여야 한다.

- ② 부서 분임정보보안담당관은 소속 부서에서 운용하는 홈페이지에서 비공개 업무자료가 무단 게시되었는지 여부를 정기적으로 점검하여야 한다.

- ③ 정보보안담당관은 홈페이지 등에 비공개 업무자료가 무단 게시된 사실을 알게 된 경우 즉시 삭제 또는 차단 등 보안조치를 취하여야 한다.

제4절 사용자 보안

제53조(개별사용자 보안) ① 정보통신망 또는 정보시스템을 운영하는 경우 그 사용과 관련하여 다음 각 호의 사항을 포함한 개별사용자 보안에 관한 절차 및 방법을 마련하여야 한다.

1. 직위·임무별 정보통신망 접근권한 부여 심사
2. 비밀 등 중요자료 취급시 비밀취급 인가, 보안서약서 징구 등 보안조치
3. 보직변경, 퇴직 등 변동사항 발생시 정보시스템 접근권한 조정

② 개별사용자는 본인이 PC 등 정보시스템을 사용하거나 정보통신망에 접속하는 행위와 관련하여 스스로 보안책임을 진다.

제54조(단말기 보안) ① 개별사용자는 지급받은 PC·노트북 등 단말기(이하 “단말기”라 한다) 사용과 관련한 일체의 보안관리 책임을 진다.

② 개별사용자는 단말기에 대하여 다음 각 호에 해당하는 보안대책을 준수하여야 한다.

1. 로그인 비밀번호의 정기적 변경 사용
2. 단말기 작업을 일정 시간 중단시 비밀번호 등을 적용한 화면보호 조치
3. 최신 백신 소프트웨어 설치
4. 운영체제 및 응용프로그램에 대한 최신 보안패치 유지
5. 출처, 유통경로 및 제작자가 불분명한 응용프로그램의 사용 금지
6. 인터넷을 통해 자료(파일) 획득시 신뢰할 수 있는 인터넷사이트를 활용하고 자료(파일) 다운로드시 최신 백신 소프트웨어로 검사 후 활용
7. 인터넷 파일공유·메신저·대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 및 공유 폴더 삭제

8. 웹 브라우저를 통해 서명되지 않은 액티브-X 등이 다운로드·실행되지 않도록 보안 설정
9. 내부망과 기관 인터넷망이 분리된 기관의 인터넷 PC에서는 특별한 사유가 없는 한 문서프로그램을 읽기 전용(專用)으로 운용
10. 그 밖에 국가정보원장이 안전성을 확인하여 배포한 프로그램의 운용 및 보안권고문 이행

③ 부서 분임정보보안담당관은 정보보안담당관 총괄 하에 개별사용자의 제2항 각 호에 해당하는 보안대책의 준수여부를 정기적으로 점검하고 개선 조치하여야 한다.

제55조(계정 관리) ① 개별사용자에게 소관 정보통신망 또는 공용(公用) 정보시스템의 접속에 필요한 사용자 계정(아이디)을 부여하고자 할 경우 다음 각 호에 해당하는 사항을 준수하여야 한다.

1. 개별사용자별 또는 그룹별 접근권한 부여
2. 외부인에게 계정을 부여하지 아니하되 업무상 불가피한 경우 기관의 장 책임 하에 보안조치 후 필요한 업무에 한하여 일정기간 동안 접속 허용
3. 특별한 사유가 없는 한 용역업체 인원에게 관리자 계정 부여 금지
4. 비밀번호 등 식별 및 인증 수단이 없는 사용자 계정은 사용 금지

② 공용(公用) 정보시스템 관리자는 개별사용자가 시스템 접속(로그온)에 5회 이상 실패할 경우 접속이 중단되도록 시스템을 설정하고 비(非)인가자의 침입여부를 점검하여야 한다.

③ 공용(公用) 정보시스템 관리자는 개별사용자의 보직변경, 퇴직, 계약종료 등 변동사항이 발생할 경우 신속히 사용자 계정을 삭제하거나 부여된 접근권한을 회수하여야 한다.

④ 공용(公用) 정보시스템 관리자는 사용자 계정 부여 및 관리의 적절성을 연2회 이상 점검하고 그 결과를 정보보안담당관에게 통보하여야 한다

- ⑤ 공용(公用) 정보시스템 관리자는 제1항 및 제3항에 의한 접근권한 부여, 변경, 회수 또는 삭제 등에 대한 내역을 기록하고 3년 이상 보관하여야 한다.

제56조(비밀번호 관리) ① 개별사용자 및 공용(公用) 정보시스템 관리자는 각종 비밀번호를 다음 각 호에 해당하는 사항을 반영하고 숫자·문자·특수문자 등을 혼합하여 안전하게 설정하고 정기적으로 변경·사용하여야 한다.

1. 사용자 계정(아이디)과 동일하지 않은 것
 2. 개인 신상 및 부서 명칭 등과 관계가 없는 것
 3. 일반 사전에 등록된 단어의 사용을 피할 것
 4. 동일한 단어 또는 숫자를 반복하여 사용하지 말 것
 5. 사용된 비밀번호는 재사용하지 말 것
 6. 동일한 비밀번호를 여러 사람이 공유하여 사용하지 말 것
 7. 응용프로그램 등을 이용한 자동 비밀번호 입력기능을 사용하지 말 것
 8. 비밀번호를 노출 또는 공개하지 말 것 <개정 '21. 6. 30>
- ② 공용(公用) 정보시스템 관리자는 서버 등 정보시스템에 보관되는 비밀번호가 복호화 되지 아니하도록 일방향 암호화하여 저장하여야 한다.
- ③ 공용(公用) 정보시스템에서 개별사용자를 식별 또는 인증하기 위하여 비밀번호에 같음하거나 병행하여 지문인식 등 생체인증 기술 및 일회용 비밀번호 생성기(OTP) 등을 안전성 확인 후 사용할 수 있다. 이 경우 생체인증 정보는 안전하게 보관하여야 한다.

제57조(전자우편 보안) ① 공제회는 전자우편을 컴퓨터바이러스·트로이목마 등 악성코드로부터 보호하기 위하여 백신 소프트웨어 설치, 해킹메일 차단시스템 구축 등 보안대책을 수립·시행하여야 한다.

② 기관 전자우편을 구축·운용할 경우 다른 전자우편과 자료를 안전하게 소통하기 위하여 전자우편시스템에 암호화 기술을 적용하여야 한다.

③ 기관 전자우편을 구축·운용할 경우 수신된 전자우편의 발신지 IP주소 및 국가명이 표시되고 해킹메일로 의심될 경우 해킹메일 원본을 전송하여 신고할 수 있는 기능을 갖추어야 한다.

④ 개별사용자는 수신된 전자우편에 포함된 첨부파일이 자동 실행되지 아니하도록 기능을 설정하고 첨부파일을 다운로드할 경우 최신 백신 소프트웨어로 악성코드 은닉여부를 검사하여야 한다.

⑤ 개별사용자는 출처가 불분명하거나 의심되는 제목의 전자우편은 열람하지 말고 해킹메일로 의심될 경우 즉시 정보보안담당관에게 신고하여야 한다. 정보보안담당관은 해킹메일로 판단될 경우 상급기관의 장에게 통보하여야 한다.

⑥ 기관 전자우편을 구축·운용할 경우 전자우편 발신자 조작 등을 통한 기관 사칭 전자우편의 유포를 차단하기 위하여 보안대책을 수립·시행하여야 한다.

제58조(비인가 기기 통제) ① 임직원등은 다음 각 호의 경우를 제외하고는 개인 소유의 정보통신기기를 소속된 기관으로 무단 반입·사용하여서는 아니 된다.

1. 보편적 통신 목적의 개인 소유 이동통신단말기(LTE·5G 등 이동통신망 접속기능이 있는 휴대폰·태블릿·스마트워치) : 반입하여 개인 용도로만 사용. 이 경우 반입 장비를 도크스테이션(dock station)·마우스·모니터·키보드 등 PC와 유사하게 활용토록 하는 장치와의 연결 사용을 금한다.

2. 제1호를 제외한 정보통신기기 : 제1호에 따른 반입·사용만으로는 보편적 통신 곤란 등 특별한 사정이 있는 경우에 한하여 소속 부서의 분임정보보안담당관을 거쳐 정보보안담당관의 승인을 받아 반입 후 개인 용도로만 사용

- ② 임직원등은 제1항 각 호에 따라 반입한 개인 소유의 정보통신기기를 소속된 기관의 내부망 및 기관 인터넷망에 연결하여서는 아니 되며, 내부망 및 기관 인터넷망 정보시스템을 다른 정보통신망에 연결하는 수단으로 사용하여서는 아니 된다. 부서 분임정보보안담당관은 이에 대하여 수시로 점검하여야 한다.
- ③ 정보보안담당관은 개인 소유의 정보통신기기가 업무자료를 외부로 유출하는데 악용될 수 있거나 소속된 기관의 정보통신망 운영에 위해(危害)가 된다고 판단될 경우 반출·입 통제, 보안소프트웨어 설치 후 반입 등 보안대책을 수립·시행하여야 한다.

제59조(위규자 처리) 개인정보보호 및 정보보안과 관련된 보안위규 발생 시 「국가공무원 복무·징계 관련 예규」(인사혁신처) 중 “비밀 엄수의 의무 위반 처리” 부분 및 국가정보원장이 배포한 「정보보안 사고(위규) 처리기준(안)」을 참고하여 위규자에 대한 처리 기준을 마련하거나, 상급기관의 처리기준을 준용할 수 있다.

- 제60조(기타)** ① 개인정보보호 및 정보보안을 위하여 추가로 필요한 사항을 정하는 경우 관계 법령, 행정규칙, 규정·지침 등에 위배되지 않게 하여야 한다.
- ② 제1항에 따라 추가로 필요한 사항을 정하는 경우, 개인정보보호책임자 및 정보보안책임자와 사전에 협의하여야 한다.

부 칙

제1조(시행일) 이 지침은 2021년 2월 16일부터 시행한다.

부 칙

제1조(시행일) 이 지침은 2021년 6월 30일부터 시행한다.

부 칙

제1조(시행일) 이 지침은 2025년 10월 1일부터 시행한다.